

HOT TOPICS · AI-DRIVEN INTRUSION

Attacks at machine speed.

Attackers now point AI agents at your network and let them probe, exploit and move in parallel. A practical playbook for shrinking the target and responding in minutes, not days.

INSIDE

Contents

A practical guide to defending against attackers who use AI agents: what was reported, how to shrink what they can reach, and how to detect and contain an intrusion that moves in minutes.

Foreword 03

Introduction 04

01 What happened 06

02 Shrink the target 09

03 Contain at speed 14

Sources 24

FOREWORD

The weaknesses were old. The pace was not.

At the end of October 2026, CrowdStrike reported that a China-nexus group had used an agentic AI penetration testing framework called ARTEX against more than 200 organisations in 11 days. A week earlier, Microsoft described a separate China-aligned group using the same framework to reach Microsoft 365 tenants through a compromised supplier application.

Look closely at how these intrusions worked and very little is new. Unrotated keys from an old directory export. A login that did not check signatures. A service left open without authentication. Password spraying. What changed is that one operator could run many attacks at once, while software tried every path in parallel and switched when one failed.

This playbook is written for UK business and IT leaders and the teams and suppliers who run their security. It covers what was actually reported, what is confirmed and what is not, and then the practical work: reduce what is exposed, harden identities, detect behaviour rather than known files, and agree in advance who can stop an attack at three in the morning.



The Transputec team
Transputec

INTRODUCTION

Three ways to keep pace with an AI attacker.

You do not need to match an attacker's AI tool for tool. You need fewer openings, faster signals and decisions that are already made before the alert fires.

Shrink the target

Find everything you expose to the internet, remove what does not need to be there and fix the rest quickly.

Harden identities

Phishing-resistant sign-in, rotated keys and least privilege for people, services and supplier apps.

Contain in minutes

Alert on behaviour, let pre-approved actions run automatically and keep a named human for the big decisions.

An AI agent does not get tired, and it does not wait until Monday.

Defence that depends on someone noticing a ticket next morning is already too slow. The answer is fewer doors, sharper alerts and containment you have agreed in advance.

01

PART 01

What happened.

Two vendor reports in October 2026 described AI agents running intrusions at a pace human teams cannot match.

01 The VAPOR PANDA campaign

02 Microsoft and Storm-0940

03 Confirmed versus claimed

WHAT HAPPENED

One operator, many agents

> **The weaknesses were old. The speed was new.**

On 29 October 2026 CrowdStrike reported that a China-nexus group it tracks as VAPOR PANDA had used ARTEX, an agentic AI penetration testing framework, against more than 200 organisations in at least 14 countries over an 11-day window starting 17 October.[1] CyberScoop, reporting an interview with CrowdStrike, said about 140 sensitive targets had been compromised and that about 70% of targets were confirmed or showed moderate-confidence signs of intrusion.[2]

Those figures need care. CrowdStrike's published post confirms post-exploitation at nine organisations, with password spraying or credential scanning against at least 12 more.[1] The 140 figure mixes confirmed and likely victims. All figures, and the China link, are CrowdStrike's; no government has published its own count.

The method is the real story. One controller ran many engagements at once, stepping in only at decision points, while agents tried web apps, cloud, containers, Active Directory and VPNs in parallel. The agents ran mainly on DeepSeek, with a second commercial model CrowdStrike could not confirm.[1]

CrowdStrike says human operators typically ran up to 40 commands an hour; with ARTEX it saw over 1,500.[2]

The ways in were familiar. An unsigned SAML assertion and an XML flaw gave cloud admin rights at a US pharmaceutical firm. An orchestration service with no authentication gave root in a container. Keys from a 2022 directory export, never rotated, let the agent forge an admin token at a Greek government body. The operator even asked the agents to find machines without endpoint protection.[1,3]

It was not the only campaign. On 21 October Microsoft said a China-aligned group, Storm-0940, had used ARTEX, an open-source framework, against hundreds of organisations, sometimes reaching privileged cloud access in under three hours, and used stolen ConnectWise app identities to try more than 2,250 tenants.[4,5] In November 2025 Anthropic reported a Chinese state-sponsored group using Claude Code against roughly 30 targets, succeeding in a small number, with AI doing 80% to 90% of the work.[6]

The NCSC said on 3 November that AI is highly likely to increase the scale and efficiency of vulnerability exploitation within two years.[7] The lesson is not that attacks are unstoppable. Old weaknesses are found and used faster, so your time to fix or contain them is shrinking.

CONFIRMED OR CLAIMED

What we know, and how sure we are

Early reporting on live campaigns changes. This is the state of the evidence on 4 November 2026.[1,2,4]

CLAIM	WHAT THE SOURCE SAYS	STATUS
200+ organisations	CrowdStrike: at least 14 countries, from 17 October, over 11 days.	Published by CrowdStrike. Not independently verified.
About 140 compromised	CrowdStrike interview with CyberScoop. About 70% confirmed or moderate confidence.	Reported. Mixes confirmed and likely victims.
Nine intrusions	CrowdStrike blog: access, a known backdoor and follow-on reconnaissance.	Confirmed by CrowdStrike.
China link	CrowdStrike linked the ARTEX controller to VAPOR PANDA infrastructure.	Vendor assessment, not a government attribution.
AI models used	Mainly DeepSeek, plus a second commercial model.	Second model unconfirmed.
Storm-0940	Microsoft: ARTEX used to try more than 2,250 tenants via a supplier app.	Separate campaign. Data theft not established.

02

PART 02

Shrink the target.

An agent can only try the doors it can find. Close the ones you do not need and lock the rest properly.

01 External exposure management

02 Fast fixes at the edge

03 Identity hardening

EXPOSURE MANAGEMENT

See yourself the way the agent does

ARTEX tried many attack paths at once. Every service you remove is one fewer path to try.

01 Scan from the outside

Run an external scan of every domain, IP range and cloud account you own. Register for the NCSC's free Early Warning service, which alerts UK organisations to exposed services and signs of compromise.[8]

02 Reconcile with your inventory

Anything the scan finds that is not on your list gets an owner within a week, or gets switched off.

03 Remove what does not need to be there

The NCSC's advice is blunt: do not connect technology to the internet unless it needs to be.[7] Start with admin pages, test sites, open file directories and orchestration consoles.

04 Check authentication on what is left

No unauthenticated services, and single sign-on set to reject unsigned SAML assertions.[1]

05 Make it continuous

Scan weekly, alert on any new exposure and review the list with owners every month.

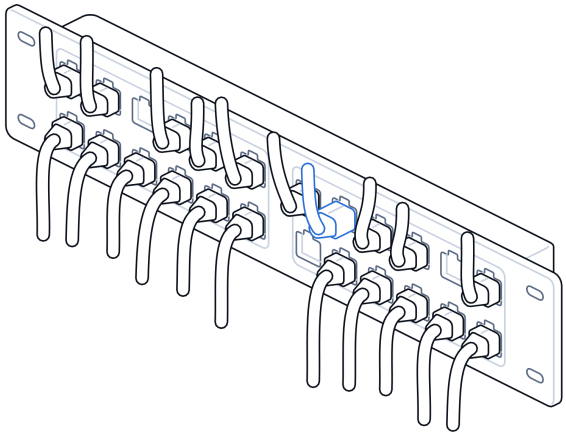
REMEMBER

Ask your supplier for the external view of your organisation in writing. If they cannot produce it, nobody is watching it.

FAST FIXES

Fix the internet-facing systems first

Our playbook No. 06 covers the patch gap in depth. Against machine-speed attackers, four points matter most.



01 **Rank by reachability**

Internet-facing systems and anything that handles sign-in come before everything else in the queue.

02 **Mitigate the same day**

If an exploited flaw has no fix yet, apply the vendor's workaround or take the service offline.

03 **Include the long-lived servers**

CrowdStrike singles out internet-facing appliances and long-lived Linux servers that drift out of date.[1]

04 **Look for compromise after**

A patch closes the door but does not remove a web shell already planted. Check before you close the ticket.

IDENTITY HARDENING

Six rules for identities under automated attack

The October campaigns turned passwords, keys and app permissions into access. These rules come from the vendor reports.

01 **Phishing-resistant sign-in for people**

Passkeys or hardware keys for every user and admin, so a sprayed or stolen password is not enough.

02 **Rotate keys after any exposure**

Signing keys, service credentials and secrets, including those in old backups and directory exports.[1]

03 **Least privilege for apps**

A compromised high-privilege app can reach far beyond its job. Cut supplier app permissions to what they need.[4]

04 **Lock down cloud metadata and roles**

Require IMDSv2 and limit which roles can run commands across many instances.[1]

05 **Alert on identity changes**

New app credentials, consent grants and privileged role assignments should alert within minutes.[4]

06 **Blunt the spray**

Microsoft saw failures peak at 2,900 a minute. Use smart lockout and conditional access, and block legacy sign-in.[4]

01

Treat every connected app as an identity

In the ConnectWise case, stolen app identities reached customer tenants without any user signing in. Supplier apps deserve the same scrutiny as admin accounts.

WHY IT MATTERS

An app with broad rights can read mail, change roles and add credentials, and no user ever sees a prompt.

WHERE TO START

List every enterprise app and consent grant with high privileges. Search by application ID, not display name.

WHAT TO CHANGE

Remove unused apps, cut permissions, require admin consent, rotate secrets and set alerts on credential changes.

WHAT TO MEASURE

Number of high-privilege apps, share with a named owner, and minutes needed to disable one.

OWNER

Identity lead, with procurement

Bring this to the monthly review, with a date for each action.

03

PART 03

Contain at speed.

Assume something gets in. The race is between the agent's next step and your first decision.

01 Detection that watches behaviour

02 Automated containment, human approval

03 Rehearse the race

DETECTION

Behaviour signals worth an alert

Agents change tools and paths quickly, so watch for patterns of behaviour rather than known files.[1,4]

SIGNAL	WHAT IT LOOKS LIKE	FIRST RESPONSE
Sign-in bursts	Thousands of failures across many accounts in minutes from few sources.	Block sources, confirm lockout works, check for any success.
Machine-pace commands	Dozens of reconnaissance commands a minute from one host or account.	Isolate the host and suspend the account pending review.
Coverage checks	Process or folder listings that look for security tools.	Treat as hands-on intrusion. Hunt for unprotected hosts.
New app powers	Secrets added to apps, self-assigned admin roles, new consent grants.	Disable the app, preserve logs, revoke the change.
Web shells and tunnels	New script files on web servers, unexpected tunnelling tools.	Isolate the server and collect evidence before rebuilding.
Bulk secret reads	Many reads from a secrets store in a short time.	Rotate the secrets and review the identity used.

CONTAINMENT

Automated containment with human approval

Small, reversible actions run on their own. Big ones need a named person who can answer within minutes, day or night.

Detect

A high-confidence behaviour rule fires, enriched with who, what and where.

Contain within limits

Pre-approved actions run at once: isolate a laptop, end a session, block an address. Each can be undone.

Approve the big moves

Disabling a service account, isolating servers or cutting supplier access needs a named approver, reachable around the clock.

Investigate and widen

Scope the intrusion and hunt for the same pattern on other hosts, accounts and tenants.

Recover and tune

Restore, rotate credentials, review false alarms and adjust the rule.

> **Agree in writing which actions your SOC may take without asking, and who answers the phone at 3am for the rest.**

AI ON DEFENCE

Using AI on defence, responsibly

AI helps defenders sort, summarise and test faster. It needs the same limits you would set for any powerful account.

Triage and summarise

Let AI group alerts and draft incident summaries so analysts spend time on decisions, not reading.

Test yourself first

Authorised, scoped testing of your own exposure. The NCSC suggests validating configurations, possibly with agentic tools.[9]

Fence the agent

Give each defensive agent its own identity, minimal short-lived permissions, a sandbox and full logging.[9]

Keep a stop button

Humans in or on the loop, with real-time alerts and the ability to halt the agent quickly.[9]

> **Do not buy AI because the attacker has it. Buy faster, better decisions, and measure whether you got them.**

TABLETOP

A 90-minute exercise for a fast-moving intrusion

Build on the NCSC's free Exercise in a Box and add these injects.[10]

01 **Set the scene**

02:10 on a Saturday. Your MSP sees thousands of failed sign-ins a minute, then one success through a supplier app.

02 **Inject one, minute 15**

New credentials are added to that app and it assigns itself an admin role in your tenant.

03 **Inject two, minute 30**

A web shell appears on a public server and the attacker starts listing hosts without endpoint protection.

04 **Decide**

Who can disable the supplier app, isolate servers and brief the board? Time each decision.

05 **Debrief**

Record decision times, gaps in authority and missing logs. Fix the top three within a month.

REMEMBER

The number that matters is minutes from first alert to containment. Write it down and try to halve it.

IN PRACTICE

Three organisations, three fast intrusions

LAW FIRM, 120 STAFF

Password spray against Microsoft 365

THE RISK

Some accounts still on password-only sign-in, including a shared mailbox.

THE FIX

Phishing-resistant MFA, legacy sign-in blocked, smart lockout and a sign-in burst alert.

THE CHECK

A simulated burst raises an alert and a call within ten minutes.

WATCH OUT

Service accounts quietly excluded from MFA rules.

MANUFACTURER WITH CLOUD WORKLOADS

Old keys, new attacker

THE RISK

Years-old directory exports with live keys sitting on a file share.

THE FIX

Keys rotated, old exports deleted, IMDSv2 required, command rights narrowed.

THE CHECK

Quarterly scan of shares and repositories for secrets.

WATCH OUT

Rotation can break integrations. Plan and test it.

CHARITY WITH AN MSP

Supplier app with too much power

THE RISK

A backup app held broad Microsoft 365 rights that nobody reviewed.

THE FIX

Permissions cut, alerts on app credential changes, MSP allowed to disable it.

THE CHECK

Disable the app in a test and time how long it takes.

WATCH OUT

Backups pause while the app is off. Agree a fallback.

YOUR PLAN

This week, this month, this quarter

Owners are suggestions. Adjust them to your structure.

WHEN	ACTIONS	OWNER
This week	Run an external scan and register for Early Warning. Remove exposed admin pages and unauthenticated services.	IT lead
This week	Review high-privilege apps and consent grants. Confirm MFA on every account, including service accounts.	Identity lead
This month	Rotate old keys and secrets. Turn on alerts for identity changes and sign-in bursts. Report EDR coverage.	Security lead
This month	Agree containment rules with your MSP or SOC, with named approvers around the clock.	Head of IT
This quarter	Run the tabletop. Measure minutes to contain. Move to continuous exposure monitoring.	Head of IT
This quarter	Report exposure, coverage and containment times to the board, with dated actions.	IT director

FOR LEADERS

Questions for your board and your MSP or SOC

Ask them out loud. Vague answers are the finding.

FOR THE BOARD

- ? Do we know everything we expose to the internet, and how fast is a new exposure spotted?
- ? If an attack began at 2am on Saturday, how many minutes until someone could contain it?
- ? Which suppliers hold privileged access to our cloud, and could we cut it off quickly?

FOR YOUR MSP OR SOC

- ? Which actions can you take without calling us, and how fast?
- ? Do you alert on sign-in bursts, new app credentials and role changes?
- ? What share of our servers, including internal ones, report to EDR?
- ? How do you use AI in your service, and who checks its decisions?

CHECKLIST

Are you ready for machine speed?

Tick what is true today. Anything blank is your next action.

- [ ] **External exposure scanned weekly**
  And every finding has an owner.

- [ ] **Registered for NCSC Early Warning**
  With alerts going to someone who acts.

- [ ] **No unauthenticated services on the internet**
  SAML signatures validated everywhere.

- [ ] **Phishing-resistant MFA for people**
  Legacy sign-in blocked.

- [ ] **High-privilege apps reviewed**
  Unused removed, the rest with owners and alerts.

- [ ] **Old keys and secrets rotated**
  Including backups and directory exports.

- [ ] **EDR on every server and laptop**
  With an alert when one stops reporting.

- [ ] **Containment rules agreed and rehearsed**
  Named approvers, timed in a tabletop.

GLOSSARY

Words worth knowing

Agentic AI

AI that plans and carries out multi-step tasks, using tools, with little human direction.

ARTEX

An open-source AI penetration testing framework that both reported campaigns used.

Penetration testing

Authorised simulated attacks to find weaknesses before criminals do.

Exposure management

Continuously finding and reducing what your organisation exposes to the internet.

Password spraying

Trying a few common passwords against many accounts to avoid lockouts.

SAML

A standard for single sign-on. Assertions must be signed and checked.

Service principal

The identity an application uses to access your cloud tenant.

EDR

Endpoint detection and response: software that watches device behaviour and can isolate a host.

Web shell

A malicious script placed on a web server to give an attacker remote control.

Human in the loop

A person must approve key actions before an automated system takes them.

SOURCES

Sources and notes

Sources were accessed in November 2026. Where reports differ, we say so in the text. Early reporting on live incidents can change.

1 CrowdStrike, VAPOR PANDA Uses AI-Driven ARTEX to Scale a Global Espionage Campaign, 29 Oct 2026. crowdstrike.com/en-us/blog/vapor-panda-uses-artex-to-scale-global-campaign/

2 CyberScoop, China-backed threat group used agentic AI pentesting tool to compromise 140 sensitive targets in 11 days, 30 Oct 2026. cyberscoop.com/china-vapor-panda-agentic-ai-artex-campaign-crowdstrike/

3 CSO Online, Armed with AI, hackers target endpoint security blind spots, raising stakes for CISOs, 3 Nov 2026. csoonline.com/article/4243816/

4 Microsoft Security Blog, AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise, 21 Oct 2026. microsoft.com/en-us/security/blog/2026/10/21/storm-0940-uses-artex-agentic-ai-connectwise-supply-chain-compromise/

5 CyberScoop, Microsoft pins ConnectWise supply-chain attack to China-state aligned threat group, 21 Oct 2026. cyberscoop.com/microsoft-attributes-connectwise-supply-chain-attack-china-storm-0940/

6 Anthropic, Disrupting the first reported AI-orchestrated cyber espionage campaign, 13 Nov 2025. anthropic.com/news/disrupting-AI-espionage

7 NCSC, Cyber chief: UK facing AI-powered attacks on critical infrastructure within two years, 3 Nov 2026. ncsc.gov.uk/news/cyber-chief-uk-facing-ai-powered-attacks-on-critical-infrastructure-in-two-years

8 NCSC, Early Warning service. ncsc.gov.uk/information/early-warning-service

9 NCSC, Managing the cyber risk of agentic AI (interim blog), 20 Aug 2026. ncsc.gov.uk/blogs/managing-the-cyber-risk-of-agentic-ai

10 NCSC, Exercise in a Box. ncsc.gov.uk/information/exercise-in-a-box

TRANSPUTEC

Ready for attacks at machine speed?

Transputec helps UK organisations map and shrink their external exposure, harden identities and supplier apps, and run round-the-clock detection with containment you have agreed in advance.

Book an exposure review

transputec.com

NEXT IN THE SERIES

No. 11 · One code, full access

